SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct: (192472330)

I N. Sunil Kumar *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

ASSESSMENT TOOL

ITA1406 - Ethical Hacking

N. Sunil Kumar
192472330

(1) Testing a vulnerability outside the authorized scope

If I discover a critical vulnerability that is not included in the company's authorization email, I will not exploit it without obtaining additional permission.

Ethical hacking principles to follow :-

(1) authorization :- I must perform security Testing only on systems and vulnerabilities covered by the approved scope.

(2) Responsible disclosure : I will not immediately inform the client about the vulnerability through a secure communication channel.

(3) Avoid unnecessary exploitation : I will not access sensitive information, Modify data, or disrupt the system to prove the vulnerability.

(4) Document the findings :- I will record the vulnerability, its possible impact, and the evidence collected without causing harm.

Conclusion :-

Ethical hackers must respect authorization boundaries, protect confidential information, and report vulnerabilities responsibly.



(2) Testing SQL injection in a production database :-

When a production database contains real costomer financial information, I must perform the penetration test carefully to avoid exposing or damaging sensitive data.

Precautions and procedures :-

(1) obtain written permission : confirm that SQL injection testing is explicity included in the engagement scope.

(2) use a test environment :- When ever possible, reproduce the vulnerability in a staging environment with synthetic or ananymized data.

(3) Take backups :- Ensure that verified backups and a recovery plan are available before Testing production systems.

(4) use non- destructive techniques : avoid queries That delete, Modify, or extract actual

customer records. use minimal test inputs to confirm the vulnerability.

Conclusion :- SQL injection testing must prioritize customer privacy, data integrity, and availability. Testing should be controlled, authorized, and non destructive.

(3) Accidental Denial of Service During a Penetration Test :-

If my penetration test accidentally causes a denial-of-service condition on a live production server, I must immediately take responsibility and follow the incident-response procedure.

Steps to take :-

① Stop testing immediately :- Terminate the activity that caused the outage and avoid repeating the request or attack.

② Notify the client :- Contact the designated Technical and Security Teams immediately and explain what happened.

③ preserve evidence :- Securely record the time of the incident, the testing activity, relevant logs and observed effects without altering.

(5) Investigate the cause :- Determine which action triged the outage and identify the Technical or procedural weakness involved.

Conclusion :-

The immediate priority is to stop the harmful activity, notify the client, and help restore normal operations. preventing futher damage is more important than completing the Test.

(4)

Penetration Testing without informing the it Department :-

If a client requests a penetration test without informing the it department to evaluate its real world detection capabilites, The engagement resembles a convert or stealth penetration test

Risk involved :-

(1) Service disruption :- Security testing May accidentally interrupt business operations

(2) false abarms :- Monitoring systems May interpret the test as a genuine cyberattack.

(3) legal issue :- Testing without clearly documented authorization May create legal and contractual problems.

(4) Incident response Confusion :- the it team May initiate emergency procedure or block legimate Business systems.

How I would structure the engagement :-

① obtain written authorization from an appropriate executive or system owner.

② Establish an emergency contact and a confidential escalation procedure.

③ Conduct a debriefing with the it and security Teams after the exercise.

---

(5) Read Team exercise VS Vulnerability Assessment in a Bank :-

A Red team exercise simulates real world attacks to test a bank's physical and digital security, including employee awareness and incident response. It requires written authorization, clear rules, and safety precautions to protect customer data and banking services.

A vulnerability assessment identifies security weaknesses such as outdated software weak passwords and system misconfigurations.

It prioritizes risks and recommends solutions.

Ethical considerations :- Both activities require written authorization, a clearly defined scope, data confidentiality and precautions.

Conclusion :- A vulnerability assessment identifies weaknesses, while a red team exercise tests how effectively the bank detects and responds to attacks.